

Threat Modeling

Hasil Vulnerability Assessment Awal

Perancangan dan Implementasi Protokol Keamanan AAA pada Sistem Informasi
NEMU IPB

Sistem	NEMU IPB - Sistem informasi pelaporan barang hilang dan ditemukan
Fokus proyek	Authentication, Authorization, Accounting (AAA), dan fitur kriptografi
Tanggal dokumen	18 May 2026
Status	Assessment awal berbasis review kode sumber lokal

Ringkasan eksekutif. Assessment awal menemukan fondasi keamanan yang sudah tersedia, seperti password hashing, JWT, role admin, activity log, hash dokumen, dan digital signature. Namun masih terdapat beberapa risiko penting, terutama endpoint yang belum dilindungi autentikasi, kontrol akses kepemilikan data yang belum konsisten, konfigurasi CORS yang longgar, dan accounting yang belum mencatat seluruh aktivitas sensitif.

Severity	Jumlah	Tema utama
Critical	1	Endpoint data pengguna terbuka tanpa autentikasi.
High	4	Data laporan/serah terima/notifikasi dapat diakses atau diubah tanpa kontrol memadai.
Medium	6	Logging tidak lengkap, CORS longgar, rate limit belum ada, validasi file terbatas, dan kelemahan key management.
Low	2	Hardening token dan hygiene konfigurasi perlu diperjelas.

Catatan: severity ditentukan berdasarkan dampak terhadap confidentiality, integrity, availability, kemudahan eksploitasi dari permukaan API, dan posisi fitur terhadap proyek AAA.

1. Ruang Lingkup dan Asumsi

Threat modeling ini dilakukan pada sistem NEMU IPB yang sudah ada. Fokusnya adalah modul backend FastAPI, frontend React sebagai client, penyimpanan data relasional, serta fitur keamanan yang relevan dengan AAA dan kriptografi. Assessment ini bersifat awal dan berbasis review kode, sehingga belum mencakup uji penetrasi penuh, uji beban, atau verifikasi konfigurasi server produksi.

Komponen yang masuk scope:

- Endpoint autentikasi, validasi JWT, dan password hashing.
- Endpoint admin, laporan, barang, notifikasi, klaim, dan serah terima.
- Kontrol akses berbasis role admin dan kepemilikan data pengguna.
- Activity log sebagai mekanisme accounting.
- Hash dokumen, digital signature RSA, dan verifikasi dokumen serah terima.

Asumsi awal:

- Aplikasi digunakan oleh pengguna internal kampus dan admin pengelola.
- Database menyimpan data pribadi, data laporan, data klaim, dan bukti serah terima.
- Frontend berkomunikasi dengan backend melalui HTTP API dan membawa JWT pada header Authorization.
- File environment seperti DATABASE_URL dan SECRET_KEY tidak boleh dipublikasikan.

2. Model Sistem dan Trust Boundary

Model ancaman menggunakan sudut pandang data flow sederhana. Aset bergerak dari browser pengguna menuju backend API, kemudian diproses oleh modul bisnis dan disimpan ke database. Batas kepercayaan utama berada di antara browser dan API, API dan database, serta endpoint publik dan endpoint yang memerlukan autentikasi.

Elemen	Komponen	Threat boundary
External entity	Pengguna umum dan admin melalui browser React	Tidak dipercaya sebelum login dan validasi token.
Process	FastAPI routers: auth, barang, laporan, admin, notifikasi, klaim, serah-terima	Harus memvalidasi autentikasi, otorisasi, dan input.
Data store	Database relasional via SQLAlchemy	Aset sensitif; akses hanya melalui backend yang tervalidasi.
Crypto service	JWT signing, password hashing, SHA-256, RSA digital signature	Kunci dan secret harus dilindungi dari kebocoran dan manipulasi.
Audit store	Tabel activity_logs	Harus menjaga integritas jejak tindakan penting.

Aset utama yang dilindungi:

Aset	Nilai keamanan	Dampak jika terganggu
Data pengguna dan password hash	Confidentiality tinggi	Kebocoran identitas, takeover akun, dan pelanggaran privasi.

Aset	Nilai keamanan	Dampak jika terganggu
Token JWT	Confidentiality dan integrity tinggi	Session hijacking atau akses endpoint terlindungi.
Data laporan dan barang	Integrity dan availability tinggi	Laporan palsu, status barang salah, atau pencarian tidak akurat.
Data klaim	Integrity tinggi	Barang dapat diklaim oleh pihak yang tidak sah.
Dokumen serah terima	Integrity dan non-repudiation tinggi	Bukti pengembalian barang dapat dipalsukan.
Activity log	Integrity tinggi	Audit tidak dapat dipercaya saat investigasi insiden.
SECRET_KEY dan DATABASE_URL	Confidentiality sangat tinggi	Token dapat dipalsukan atau database dapat diakses langsung.

3. Threat Modeling STRIDE

STRIDE digunakan untuk memetakan ancaman terhadap fitur AAA dan aset kriptografi. Tabel berikut merangkum ancaman utama, skenario, kontrol yang sudah ada, dan rekomendasi kontrol tambahan.

Kategori	Skenario ancaman	Kontrol existing	Kontrol tambahan
Spoofing	Penyerang mencoba login dengan kredensial hasil tebakan atau token curian.	Password hash, JWT bearer token, expiry token.	Rate limit login, logout bertahap, audit login gagal, secret rotation.
Tampering	Status laporan, status barang, atau dokumen serah terima dimodifikasi.	Endpoint admin untuk status, SHA-256 dan digital signature pada serah terima.	Otorisasi ketat, audit status lama/baru, trust anchor key signing.
Repudiation	Admin atau user menyangkal tindakan verifikasi, klaim, atau ekspor data.	Tabel activity_logs untuk beberapa aksi admin.	Log semua aksi sensitif termasuk login, klaim, export, dan verifikasi serah terima.
Information disclosure	Data user, laporan, notifikasi, atau serah terima dibaca pihak tidak berhak.	Beberapa endpoint memakai get_current_user dan ensure_admin.	Tutup endpoint publik sensitif, periksa kepemilikan data, minimalkan response.
Denial of service	Request login/search/filter berulang atau bug runtime mengganggu layanan.	Validasi Pydantic pada beberapa input.	Rate limit, pagination, query bounds, perbaiki bug schema penemuan.
Elevation of privilege	Pengguna umum mengakses fitur admin atau data milik pengguna lain.	Role admin pada beberapa endpoint.	Centralized authorization dependency, test akses negatif per endpoint.

4. Hasil Vulnerability Assessment Awal

Temuan berikut disusun dari review kode sumber lokal. Evidence merujuk pada perilaku endpoint atau konfigurasi yang terlihat pada modul aplikasi. Daftar ini menjadi baseline perbaikan untuk proyek akhir AAA.

VA-01 - Endpoint /auth/users tidak dilindungi autentikasi.

Severity	Evidence	Dampak	Rekomendasi
Critical	Router auth menyediakan GET /auth/users tanpa dependency get_current_user. Response berisiko memuat data user sensitif termasuk password_hash.	Confidentiality data pengguna sangat terdampak dan dapat menjadi awal takeover akun.	Lindungi endpoint dengan admin-only atau hapus endpoint dari produksi. Gunakan response model yang mengecualikan password_hash.

VA-02 - Endpoint laporan publik membuka data laporan.

Severity	Evidence	Dampak	Rekomendasi
High	GET /laporan dan GET /laporan/{laporan_id} tidak menggunakan autentikasi. Detail laporan mengembalikan pelapor, email, status, dan data barang.	Pengguna tidak sah dapat membaca data laporan dan identitas pelapor.	Tambahkan autentikasi, filter berdasarkan kepemilikan user, dan admin-only untuk daftar global.

VA-03 - Endpoint notifikasi read tidak memvalidasi user dan ownership.

Severity	Evidence	Dampak	Rekomendasi
High	PATCH /notifikasi/{id}/read tidak memakai get_current_user dan tidak memeriksa Notifikasi.user_id.	Pihak tidak sah dapat mengubah status notifikasi milik pengguna lain.	Tambahkan get_current_user dan filter notifikasi_id bersama current_user.user_id.

VA-04 - Endpoint pengambilan serah terima belum memeriksa ownership.

Severity	Evidence	Dampak	Rekomendasi
High	GET /serah-terima/{klaim_id} memerlukan login tetapi mengembalikan dokumen berdasarkan klaim_id tanpa memeriksa admin atau user pemilik.	User login lain dapat membaca dokumen serah terima yang bukan miliknya.	Samakan kontrol dengan endpoint verify: hanya admin atau user pemilik dokumen.

VA-05 - Konfigurasi CORS terlalu longgar.

Severity	Evidence	Dampak	Rekomendasi
High	Backend mengatur allow_origins=["*"], allow_methods=["*"], allow_headers=["*"], dan allow_credentials=True.	Memperluas permukaan serangan dari origin tidak terpercaya, terutama jika token disimpan di client.	Batasi origin ke domain frontend resmi dan pisahkan konfigurasi dev/production.

VA-06 - Accounting belum mencatat seluruh aktivitas sensitif.

Severity	Evidence	Dampak	Rekomendasi
Medium	Activity log sudah ada untuk verifikasi laporan dan update status barang, tetapi belum konsisten untuk login gagal/berhasil, pengajuan klaim, verifikasi klaim, serah terima, dan ekspor.	Audit trail tidak lengkap ketika terjadi insiden.	Standarkan helper logging dan panggil pada semua aksi AAA sensitif.

VA-07 - Tidak ada rate limiting atau lockout login.

Severity	Evidence	Dampak	Rekomendasi
Medium	Endpoint login memverifikasi password tetapi belum terlihat kontrol pembatasan percobaan.	Risiko brute force dan credential stuffing meningkat.	Tambahkan rate limit per IP/user, delay bertahap, dan log percobaan gagal.

VA-08 - Key management digital signature belum memiliki trust anchor kuat.

Severity	Evidence	Dampak	Rekomendasi
Medium	Key pair RSA dibuat saat serah terima, public key disimpan bersama signature dan dokumen. Jika database dapat dimodifikasi, attacker dapat mengganti dokumen, hash, signature, dan public key sekaligus.	Integritas dokumen bergantung penuh pada integritas database.	Gunakan signing key server yang dikelola terpisah, simpan public key tepercaya, dan audit perubahan dokumen.

VA-09 - Validasi dokumentasi barang hanya berbasis ekstensi.

Severity	Evidence	Dampak	Rekomendasi
Medium	Schema memvalidasi dokumentasi dengan ekstensi .jpg/.jpeg/.png/.webp, belum memvalidasi MIME, ukuran, atau storage path.	Risiko file spoofing, referensi path tidak valid, atau konten berbahaya jika upload ditambahkan.	Validasi MIME, ukuran, lokasi penyimpanan, dan gunakan object storage/path sanitizer.

VA-10 - Endpoint barang publik mengembalikan seluruh data barang.

Severity	Evidence	Dampak	Rekomendasi
Medium	GET /barang, search, status, dan filter dapat diakses tanpa login dan mengembalikan lokasi, dokumentasi, dan status.	Jika data barang dianggap internal, terjadi information disclosure.	Tentukan kebijakan publik; tampilkan hanya barang terverifikasi dan minimalkan data sensitif.

VA-11 - Bug pada laporan penemuan dapat menyebabkan kegagalan runtime.

Severity	Evidence	Dampak	Rekomendasi
Medium	Fungsi buat_laporan_penemuan mengakses data.user_id, sementara schema LaporanCreate tidak memiliki field user_id.	Endpoint penemuan berpotensi gagal dan mengganggu availability fitur.	Gunakan current_user.user_id seperti laporan kehilangan dan tambahkan test endpoint penemuan.

VA-12 - JWT hardening belum lengkap.

Severity	Evidence	Dampak	Rekomendasi
Low	Token memuat user_id, username, role, dan exp, tetapi belum terlihat issuer, audience, token id, atau mekanisme revocation.	Kontrol sesi masih dasar dan sulit dicabut sebelum expiry.	Tambahkan iss, aud, jti, refresh strategy, dan blacklist/rotation jika diperlukan.

VA-13 - Konfigurasi secret perlu fail-fast dan dokumentasi environment.

Severity	Evidence	Dampak	Rekomendasi
Low	SECRET_KEY diambil dari environment. Jika kosong atau lemah, signing JWT menjadi berisiko.	Kesalahan deployment dapat melemahkan seluruh autentikasi.	Validasi SECRET_KEY saat startup dan dokumentasikan minimum entropy serta rotasi secret.

5. Prioritas Remediasi

Prioritas perbaikan disusun agar proyek akhir langsung memperkuat komponen AAA yang paling berisiko. Urutan berikut disarankan untuk sprint implementasi.

Prioritas	Area	Aksi utama
P0	Data exposure	Amankan /auth/users, /laporan, /laporan/{id}, /notifikasi/{id}/read, dan /serah-terima/{klaim_id}.
P0	Authorization	Buat dependency admin_required dan owner_or_admin_required yang dipakai konsisten.
P1	Accounting	Catat login, login gagal, klaim, verifikasi klaim, serah terima, export, dan akses ditolak.
P1	CORS	Batasi origin produksi dan pisahkan konfigurasi development.
P1	Authentication	Tambahkan rate limiting, lockout bertahap, dan audit percobaan login.
P2	Kriptografi	Perbaiki key management digital signature dengan signing key yang menjadi trust anchor.
P2	Data minimization	Batasi response publik barang/laporan dan gunakan response schema eksplisit.
P2	Quality	Tambahkan test negatif untuk akses tanpa token, role salah, dan data bukan milik user.

6. Rencana Pengujian Keamanan

Skenario uji	Kontrol yang diuji	Ekspektasi
Akses endpoint admin dengan user biasa	Authorization	HTTP 403 dan log akses ditolak tercatat.
Akses /laporan/{id} milik user lain	Owner-based access	HTTP 403 atau data tidak ditemukan.
PATCH notifikasi milik user lain	Owner-based access	Status notifikasi tidak berubah.
GET serah terima klaim user lain	Confidentiality	HTTP 403.
Login password salah berulang	Authentication hardening	Rate limit/lockout aktif dan log gagal tercatat.
Admin export laporan	Accounting	Export berhasil dan activity log mencatat admin serta waktu.
Dokumen serah terima dimodifikasi	Integrity crypto	Hash/signature verification gagal.
JWT dimodifikasi manual	JWT signing	Token ditolak.
Request dari origin tidak sah	CORS	Browser menolak akses response.

7. Kesimpulan Assessment Awal

NEMU IPB sudah memiliki fondasi keamanan yang relevan dengan proyek akhir AAA, tetapi penerapannya belum merata di seluruh endpoint. Risiko terbesar saat ini adalah kebocoran data melalui endpoint yang belum dilindungi, kontrol kepemilikan data yang belum konsisten, dan jejak accounting yang belum lengkap. Remediasi awal sebaiknya memprioritaskan penutupan endpoint

sensitif, standardisasi authorization dependency, dan perluasan activity log. Setelah itu, fitur kriptografi dokumen serah terima dapat diperkuat melalui key management yang lebih tepercaya.